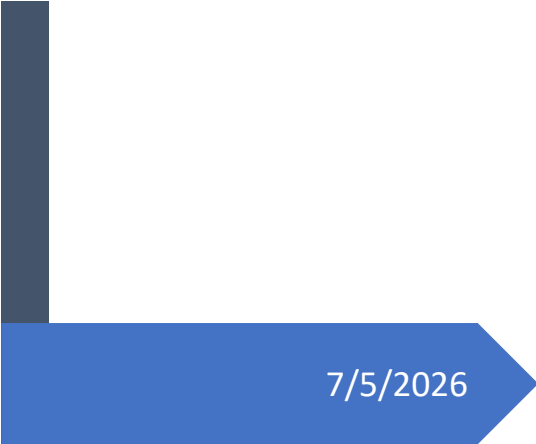


A dark blue vertical bar on the left side of the page. A blue arrow points to the right from the bar, containing the date.

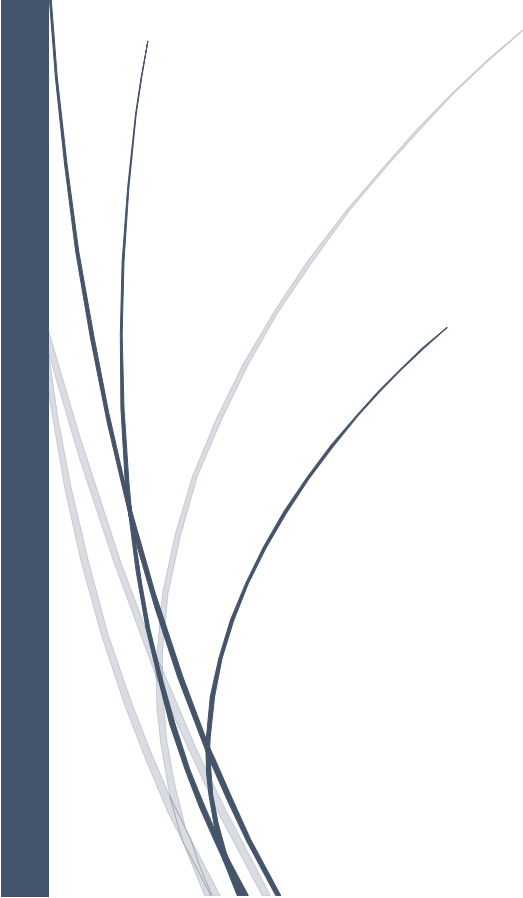
7/5/2026

Η Κοινωνική Μηχανική (Social Engineering) σε κινητές συσκευές

Χαράλαμπος Στίκος

UEL Student Number: 2677046

Επιβλέπον καθηγητής: Νικόλαος Μουχτιδιώτης

Several thin, curved lines in shades of blue and grey originate from the bottom left and curve upwards and to the right.

Χαράλαμπος Στίκος

Περιεχόμενα

Εισαγωγή.....	2
Σκοπός της Εργασίας	3
Μεθοδολογία.....	3
Δομή της Εργασίας.....	4
Evil Twin Attack Prototype	4
FAKE APP ATTACK (GOV WALLET PROTOTYPE)	10
SMS Phishing Attack (Fuel Pass III Portal Prototype).....	17
Συγκριτική Ανάλυση των Τριών Επιθέσεων.....	24
Τεχνική Πολυπλοκότητα	24
Κόστος Υλοποίησης	24
Αποτελεσματικότητα Εξαπάτησης	25
Ανιχνευσιμότητα	25
Συγκριτικός Πίνακας	26
Αντίμετρα και Μέτρα Προστασίας.....	27
Αντίμετρα για την Επίθεση Evil Twin	27
Αντίμετρα για την Επίθεση Gov Wallet	28
Αντίμετρα για την Επίθεση SMS Phishing.....	29

Εισαγωγή

Η Κοινωνική Μηχανική αποτελεί έναν από τους παλαιότερους και ταυτόχρονα διαρκώς εξελισσόμενους τρόπους παραβίασης συστημάτων ασφαλείας. Σε αντίθεση με τις παραδοσιακές κυβερνοεπιθέσεις που στρέφονται απευθείας ενάντια σε λογισμικό ή δικτυακά πρωτόκολλα η Κοινωνική Μηχανική στοχεύει στον ίδιο τον χρήστη, εκμεταλλευόμενη τις συνήθειές του, την εμπιστοσύνη που δείχνει σε γνώριμα οπτικά ερεθίσματα και τις διαδικασίες λήψης αποφάσεων που εκτελεί υπό συνθήκες πίεσης ή ρουτίνας. Ο επιτιθέμενος δεν χρειάζεται να σπάσει κάποιον αλγόριθμο κρυπτογράφησης ή να εντοπίσει μια μηδενικής ημέρας ευπάθεια. Του αρκεί να πείσει τον χρήστη να του παραδώσει εθελοντικά αυτό που τον ενδιαφέρει μέσα από ένα περιβάλλον που μοιάζει αρκετά οικείο ώστε να μην προκαλέσει υποψία.

Η μετάβαση από τους επιτραπέζιους υπολογιστές στις κινητές συσκευές έχει μετατρέψει το τοπίο της Κοινωνικής Μηχανικής με τρόπους που δεν έχουν ακόμη μελετηθεί επαρκώς. Το κινητό τηλέφωνο δεν είναι απλώς ένας μικρότερος υπολογιστής. Είναι μια συσκευή που βρίσκεται μόνιμα στο σώμα του χρήστη, που χρησιμοποιείται κάτω από τις πιο διαφορετικές συνθήκες, που εμφανίζει πληροφορίες σε περιορισμένη οθόνη και που εκτελεί κρίσιμες λειτουργίες όπως η τραπεζική, η επικοινωνία με κρατικές υπηρεσίες και η αυθεντικοποίηση πολλαπλών παραγόντων. Όλα αυτά μαζί δημιουργούν ένα περιβάλλον όπου ο χρήστης λαμβάνει αποφάσεις γρήγορα, χωρίς να μπορεί πάντα να ελέγξει σχολαστικά τα στοιχεία μιας σελίδας ή ενός μηνύματος, και όπου η εμπιστοσύνη βασίζεται κυρίως σε οπτικά σήματα όπως ένα λογότυπο, ένα όνομα domain ή το εικονίδιο ενός λουκέτου.

Παράλληλα, η ψηφιοποίηση των δημόσιων υπηρεσιών στην Ελλάδα τα τελευταία χρόνια έχει δημιουργήσει νέες ευκαιρίες αλλά και νέους κινδύνους. Πλατφόρμες όπως το gov.gr, οι κωδικοί TaxisNet και το ψηφιακό πορτοφόλι gov.gr wallet έχουν γίνει τμήμα της καθημερινότητας εκατομμυρίων πολιτών. Η εξοικείωση αυτή λειτουργεί αμφίδρομα. Από τη μία διευκολύνει τον πολίτη, από την άλλη όμως μετατρέπει τις συγκεκριμένες πλατφόρμες σε εξαιρετικά ελκυστικούς στόχους για τους επιτιθέμενους, οι οποίοι μπορούν να αναπαράγουν την αισθητική τους και να εκμεταλλευτούν την οικειότητα του χρήστη.

Σκοπός της Εργασίας

Η παρούσα πτυχιακή εργασία επιχειρεί να μελετήσει εμπράκτως πώς λειτουργεί η Κοινωνική Μηχανική σε κινητές συσκευές, μέσα από την ανάπτυξη και τεκμηρίωση τριών λειτουργικών πρωτοτύπων επίθεσης. Δεν περιορίζεται σε θεωρητική ανάλυση. Επιλέγεται η πρακτική προσέγγιση, καθώς θεωρώ ότι μόνο η πραγματική κατασκευή των επιθέσεων μπορεί να αποκαλύψει τις τεχνικές και ψυχολογικές παραμέτρους που τις καθιστούν αποτελεσματικές. Παράλληλα, η εργασία αποσκοπεί στην ανάδειξη των αδυναμιών που υπάρχουν τόσο σε επίπεδο τεχνολογίας όσο και σε επίπεδο εκπαίδευσης του τελικού χρήστη.

Τα τρία πρωτότυπα που υλοποιήθηκαν αντιπροσωπεύουν τρεις διαφορετικές κατηγορίες επιθέσεων που στοχεύουν τις κινητές συσκευές. Η πρώτη είναι η επίθεση Evil Twin, μια επίθεση σε επίπεδο δικτύου που εκμεταλλεύεται την τάση των χρηστών να συνδέονται σε ανοιχτά Wi-Fi δίκτυα. Η δεύτερη είναι μια κακόβουλη εφαρμογή Android που μιμείται το επίσημο gov.gr wallet και υποκλέπτει κωδικούς TaxisNet μέσω ενσωματωμένου WebView. Η τρίτη είναι μια επίθεση SMS phishing που εκμεταλλεύεται την επικαιρότητα της κρατικής ενίσχυσης Fuel Pass III για να παρασύρει τον πολίτη σε ψεύτικη πύλη αυθεντικοποίησης. Οι τρεις αυτές επιθέσεις δεν επιλέχθηκαν τυχαία. Καλύπτουν τα τρία βασικά διανύσματα μέσα από τα οποία ένας επιτιθέμενος μπορεί να φτάσει σε μια κινητή συσκευή, δηλαδή το δίκτυο στο οποίο συνδέεται, το λογισμικό που εγκαθιστά και τα μηνύματα που λαμβάνει.

Μεθοδολογία

Η μεθοδολογική προσέγγιση που ακολούθησα είναι αυτή της κατασκευαστικής έρευνας. Για κάθε μία από τις τρεις επιθέσεις σχεδίασα και υλοποίησα ένα πλήρως λειτουργικό prototype, το οποίο δοκιμάστηκε σε ελεγχόμενο εργαστηριακό περιβάλλον με δικές μου συσκευές. Οι δοκιμές πραγματοποιήθηκαν σε σύγχρονες εκδόσεις Android, και ανά περίπτωση σε iOS και Windows όπου ήταν εφαρμόσιμο. Η κάθε επίθεση τεκμηριώθηκε σε επίπεδο πηγαίου κώδικα, αρχιτεκτονικής και ροής δεδομένων, ενώ καταγράφηκαν οπτικά τεκμήρια σε κάθε στάδιο της εκτέλεσης.

Η συλλογή δεδομένων έγινε αποκλειστικά σε δοκιμαστικούς λογαριασμούς που δημιούργησα ο ίδιος και σε δικές μου συσκευές, ώστε να διασφαλιστεί η πλήρης συμμόρφωση με τη νομοθεσία περί προσωπικών δεδομένων και ηλεκτρονικού εγκλήματος. Σε κανένα στάδιο της έρευνας δεν στοχοποιήθηκε τρίτος, δεν εκπέμφθηκε επίθεση σε δημόσιο χώρο και δεν χρησιμοποιήθηκαν πραγματικά διαπιστευτήρια. Όλα τα στοιχεία που

εμφανίζονται στις καταγραφές των prototypes είναι κατασκευασμένα για τους σκοπούς της επίδειξης.

Η αξιολόγηση κάθε επίθεσης γίνεται με βάση τέσσερις άξονες: την τεχνική πολυπλοκότητα της υλοποίησης, το κόστος σε υλικό και χρόνο, την αποτελεσματικότητα της εξαπάτησης από τη σκοπιά του θύματος και την ευκολία ή δυσκολία ανίχνευσής της. Η συγκριτική αυτή αξιολόγηση παρουσιάζεται σε ξεχωριστή ενότητα μετά την περιγραφή των τριών prototypes, ενώ έπεται ενότητα με αναλυτικά αντίμετρα για κάθε τύπο επίθεσης.

Δομή της Εργασίας

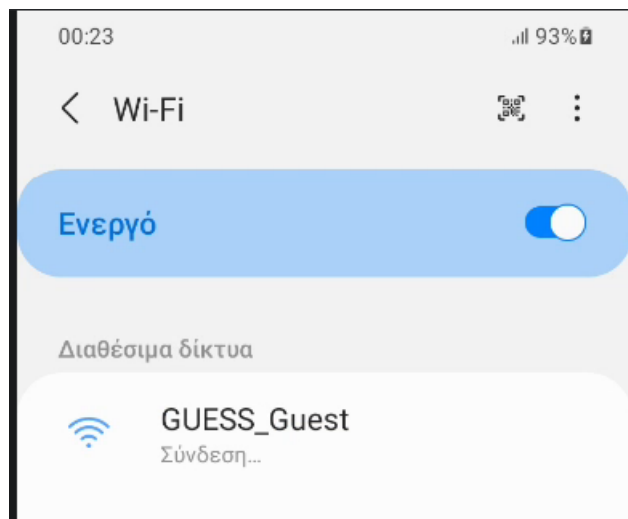
Η εργασία ξεκινά με την παρουσίαση των τριών πρωτοτύπων, ξεκινώντας από την επίθεση Evil Twin, συνεχίζοντας στην κακόβουλη εφαρμογή gon.gr wallet και ολοκληρώνοντας με το SMS phishing πρωτότυπο της πύλης Fuel Pass III. Στη συνέχεια ακολουθεί η συγκριτική ανάλυση των τριών επιθέσεων, που επιχειρεί να αναδείξει τα κοινά τους χαρακτηριστικά και τις διαφορές τους. Έπεται η ενότητα των αντιμέτρων, όπου εξετάζονται οι δυνατότητες προστασίας τόσο από τεχνική όσο και από εκπαιδευτική σκοπιά. Η εργασία κλείνει με συμπεράσματα που συνοψίζουν τα ευρήματα και τοποθετούν την έρευνα μέσα στο ευρύτερο πλαίσιο της ασφάλειας κινητών συσκευών στην Ελλάδα.

Evil Twin Attack Prototype

Στο πλαίσιο της έρευνάς μου για την Κοινωνική Μηχανική σε κινητές συσκευές, υλοποίησα ένα ολοκληρωμένο πρωτότυπο επίθεσης «Evil Twin», το οποίο συνδυάζει την παραμετροποίηση δικτύου χαμηλού επιπέδου με προηγμένες τεχνικές ψυχολογικής χειραγώγησης. Η επίθεση δεν βασίζεται απλώς στην κλοπή κωδικών, αλλά στη δημιουργία ενός απόλυτα έμπιστου περιβάλλοντος που παρακάμπτει τις άμυνες τόσο του λειτουργικού συστήματος όσο και της προσοχής του χρήστη.

Η υλοποίηση στηρίχθηκε σε λειτουργικό σύστημα Kali Linux, με χρήση των εργαλείων hostapd και dnsmasq για τη δικτυακή υποδομή, του τοίχου προστασίας iptables για τον έλεγχο της κίνησης και ενός Node.js Express διακομιστή για το captive portal. Η συνολική αρχιτεκτονική μπορεί να συνοψιστεί ως εξής: η κίνηση του θύματος εισέρχεται από το ασύρματο interface, περνάει από τους κανόνες του τοίχου προστασίας, παγιδεύεται στον τοπικό διακομιστή και μόνο μετά την αυθεντικοποίηση προωθείται στο πραγματικό διαδίκτυο μέσω της ενσύρματης διεπαφής.

Η διαδικασία ξεκινά με τη δημιουργία ενός «δόλου» σε επίπεδο υλικού. Χρησιμοποιώντας έναν εξωτερικό προσαρμογέα Wi-Fi σε κατάσταση Access Point (μέσω του εργαλείου hostapd), εξέπεμψα ένα ανοιχτό δίκτυο με το όνομα «GUESS_Guest». Η επιλογή μιας γνωστής πολυεθνικής εταιρείας είναι στρατηγική, καθώς οι χρήστες τείνουν να εμπιστεύονται ανοιχτά δίκτυα που φέρουν επίσημο branding. Παράλληλα μέσω του dnsmasq, έστησα έναν διακομιστή DHCP ο οποίος, εκτός από την απόδοση διευθύνσεων IP, χρησιμοποιεί το σύγχρονο πρωτόκολλο RFC 8910. Αυτή η λεπτομέρεια είναι κρίσιμη, καθώς επιτρέπει στη συσκευή του θύματος να αναγνωρίσει αυτόματα την ύπαρξη πύλης σύνδεσης και να εμφανίσει την ειδοποίηση «Σύνδεση στο δίκτυο» αμέσως μετά τη σύνδεση, χωρίς ο χρήστης να χρειαστεί να ανοίξει κάποιον browser.



[NETWORK CONNECT]

Το τεχνικό υπόβαθρο της επίθεσης στηρίζεται σε έναν προσεκτικά ρυθμισμένο τοίχο προστασίας (iptables). Όπως φαίνεται και στα στιγμιότυπα από την παραμετροποίηση του συστήματος, όλες οι προσπάθειες πρόσβασης σε σελίδες HTTP ανακατευθύνονται στον τοπικό μου διακομιστή Node.js, ενώ οι κλήσεις HTTPS απορρίπτονται άμεσα. Αυτό εξαναγκάζει τα λειτουργικά συστήματα (Android, iOS, Windows) να αποτύχουν στους εσωτερικούς ελέγχους συνδεσιμότητας που κάνουν στο παρασκήνιο και να «παγιδευτούν» στην πύλη που έχω δημιουργήσει.

Χαράλαμπος Στίκος

Η ΚΟΙΝΩΝΙΚΗ ΜΗΧΑΝΙΚΗ (SOCIAL ENGINEERING) ΣΕ ΚΙΝΗΤΕΣ ΣΥΣΚΕΥΕΣ

```
kali@kali: ~/Desktop/evil-twin-prototype
Session Actions Edit View Help
(kali@kali) [~/Desktop/evil-twin-prototype]
$ chmod +x setup_network.sh

(kali@kali) [~/Desktop/evil-twin-prototype]
$ sudo ./setup_network.sh
[sudo] password for kali:
Installing Node.js dependencies...

added 65 packages in 475ms
22 packages are looking for funding
  run 'npm fund' for details
Stopping NetworkManager...

Killing these processes:

  PID Name
  1549 wpa_supplicant

Configuring wlan0 with IP 10.0.0.1...
Clearing old firewall rules...
Redirecting DNS to local dnsmasq...
Redirecting HTTP port 80 to Node.js on port 3000...
Enabling NAT from wlan0 to eth0...

AP interface : wlan0
Internet      : eth0
Portal IP    : 10.0.0.1
SSID         : GUESS_Guest

Next steps (run each in a separate terminal):
1. sudo hostapd /home/kali/Desktop/evil-twin-prototype/hostapd.conf
2. sudo dnsmasq -C /home/kali/Desktop/evil-twin-prototype/dnsmasq.conf -d
3. sudo node /home/kali/Desktop/evil-twin-prototype/server.js

Captures file: /home/kali/Desktop/evil-twin-prototype/captures.txt
```

[SETUP_NETWORK]

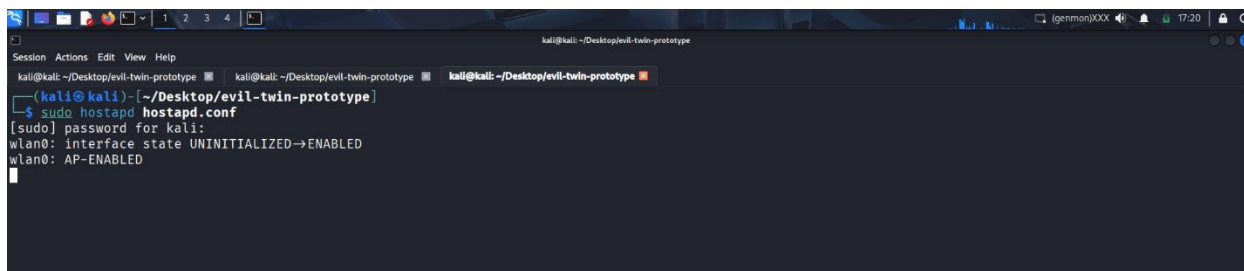
```
kali@kali: ~/Desktop/evil-twin-prototype
Session Actions Edit View Help
kali@kali: ~/Desktop/evil-twin-prototype
(kali@kali) [~/Desktop/evil-twin-prototype]
$ sudo dnsmasq -C dnsmasq.conf -d
[sudo] password for kali:
dnsmasq: started, version 2.91 cachesize 150
dnsmasq: compile time options: IPv6 GNU-getopt DBus no-UBus i18n IDN2 DHCP DHCPv6 no-Lua TFTP conntrack ipset nftset auth DNSSEC loop-detect inotify dumpfile
dnsmasq-dhcp: DHCP, IP range 10.0.0.10 -- 10.0.0.250, lease time 1h
dnsmasq: using nameserver 8.8.8.8#53
dnsmasq: reading /etc/resolv.conf
dnsmasq: using nameserver 8.8.8.8#53
dnsmasq: using nameserver 192.168.1.1#53
dnsmasq: using nameserver fe80::1%eth0#53
dnsmasq: read /etc/hosts - 7 names
```

[SETUP DNSMASQ]

Πέρα από την ανακατεύθυνση του HTTP traffic, ο τοίχος προστασίας απορρίπτει επίσης την κρυπτογραφημένη DNS κίνηση μέσω TLS, εξαναγκάζοντας τις συσκευές να επιστρέψουν σε απλό DNS που είναι ήδη υπό τον έλεγχο μου. Παράλληλα, ενεργοποιείται το IP forwarding και δηλώνεται κανόνας MASQUERADE στην έξοδο προς το ενσύρματο interface, ώστε όταν αργότερα παραχωρηθεί πρόσβαση σε ένα θύμα, η κίνησή του να μπορεί να φτάσει στο πραγματικό διαδίκτυο μέσω NAT.

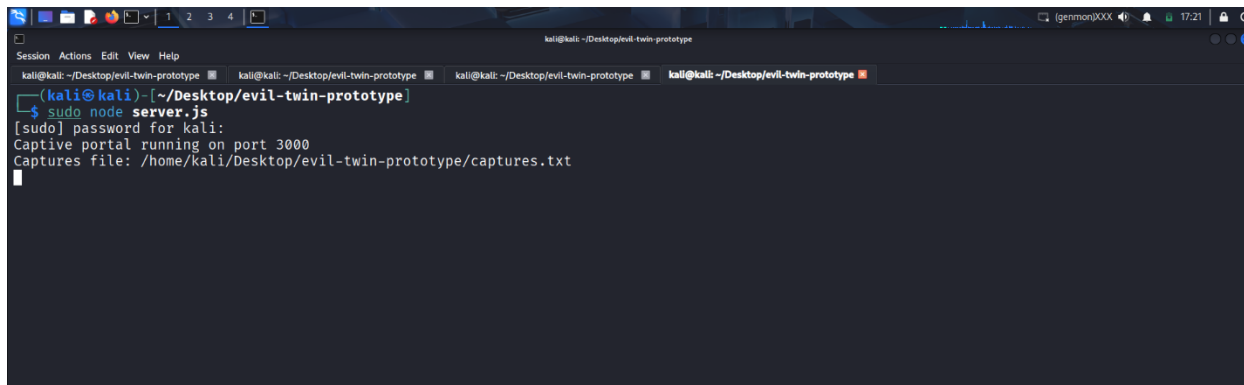
Χαράλαμπος Στίκος

Η ΚΟΙΝΩΝΙΚΗ ΜΗΧΑΝΙΚΗ (SOCIAL ENGINEERING) ΣΕ ΚΙΝΗΤΕΣ ΣΥΣΚΕΥΕΣ



```
kali@kali: ~/Desktop/evil-twin-prototype
kali@kali:~/Desktop/evil-twin-prototype$ sudo hostapd hostapd.conf
[sudo] password for kali:
wlan0: interface state UNINITIALIZED->ENABLED
wlan0: AP-ENABLED
```

[SETUP HOSTAPD]



```
kali@kali: ~/Desktop/evil-twin-prototype
kali@kali:~/Desktop/evil-twin-prototype$ sudo node server.js
[sudo] password for kali:
Captive portal running on port 3000
Captures file: /home/kali/Desktop/evil-twin-prototype/captures.txt
```

[SETUP SERVER]

Όταν ο χρήστης επιλέξει την ειδοποίηση σύνδεσης, έρχεται αντιμέτωπος με το στάδιο της Κοινωνικής Μηχανικής. Η σελίδα προσγείωσης (Landing Page) που σχεδίασα μιμείται με απόλυτη ακρίβεια την εταιρική ταυτότητα της GUESS, χρησιμοποιώντας τα επίσημα λογότυπα και μια καθαρή, επαγγελματική αισθητική. Προσφέροντας οικείες επιλογές σύνδεσης μέσω Google, Microsoft ή Apple, εκμεταλλεύομαι τη συνήθεια των χρηστών να χρησιμοποιούν τους λογαριασμούς τους για γρήγορη πρόσβαση σε τρίτες υπηρεσίες. Καθώς το θύμα εισάγει τα διαπιστευτήριά του στα modals που εμφανίζονται, ο διακομιστής Node.js τα καταγράφει σε πραγματικό χρόνο στο αρχείο captures.txt, όπως αποδεικνύεται και από τα log αρχεία της κονσόλας.

00:26 96%

Συνδεθείτε στο GUESS_Guest
10.0.0.1

GUESS
GUEST W I - F I

WELCOME

Please sign in to connect to the GUESS guest network.
Access is for authorized visitors only.

Continue with Google

Continue with Microsoft

Continue with Apple

OR

Full name

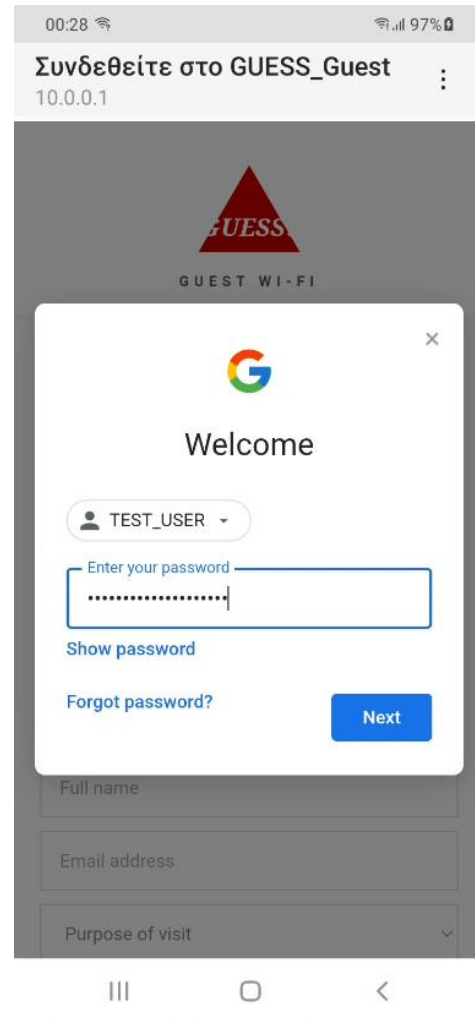
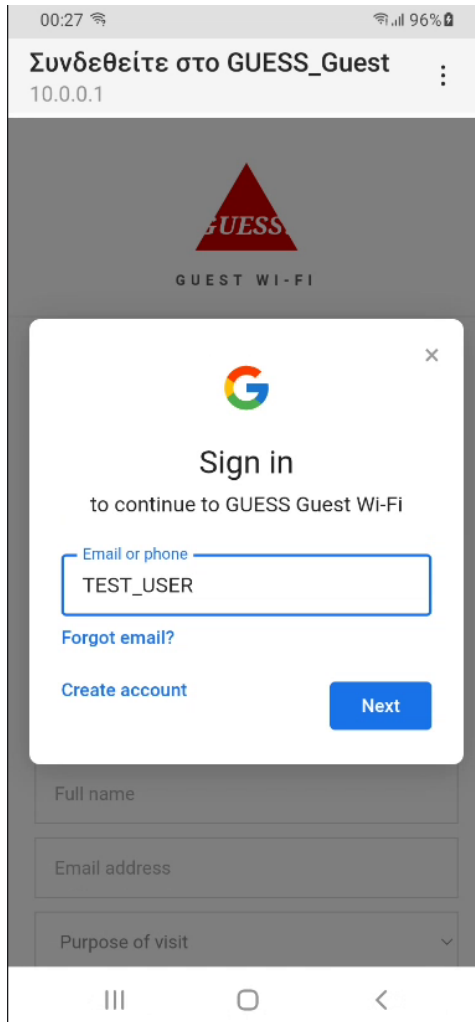
Email address

Purpose of visit

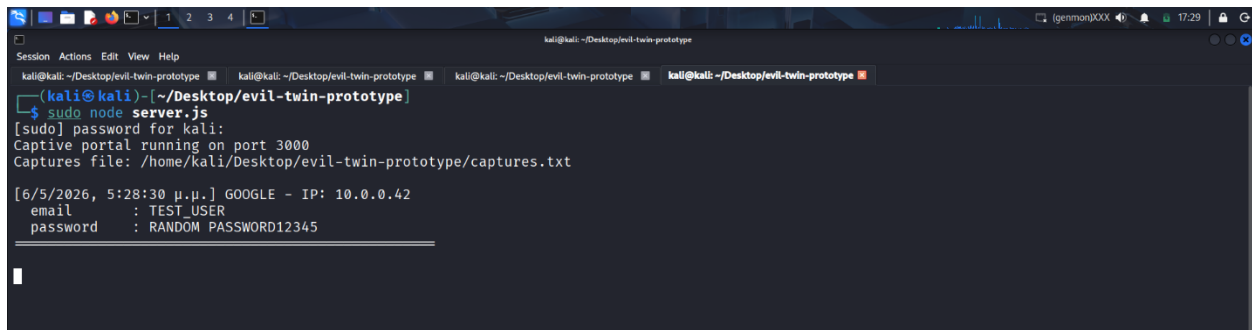
[EVIL TWIN LANDING PAGE]

Κάθε ένα από τα τρία κουμπιά σύνδεσης ανοίγει ένα modal παράθυρο που μιμείται με ακρίβεια την αντίστοιχη πραγματική σελίδα του παρόχου. Το modal της Google ακολουθεί τη γνωστή διαδικασία δύο βημάτων, ζητώντας πρώτα το email και έπειτα τον κωδικό σε ξεχωριστή οθόνη, ενώ το modal της Microsoft λειτουργεί με τον ίδιο τρόπο διατηρώντας τη χαρακτηριστική Segoe UI γραμματοσειρά και τα χρώματα της εταιρείας. Το αντίστοιχο modal της Apple εμφανίζει και τα δύο πεδία ταυτόχρονα, με τη γνωστή στρογγυλεμένη αισθητική. Όλες οι λεπτομέρειες, από τα λογότυπα και τα χρώματα μέχρι τους «ψεύτικους» συνδέσμους «Forgot password?» και «Create account», έχουν προστεθεί ώστε να μην αφήνουν περιθώριο αμφιβολίας στον χρήστη.

Χαράλαμπος Στίκος
Η ΚΟΙΝΩΝΙΚΗ ΜΗΧΑΝΙΚΗ (SOCIAL ENGINEERING) ΣΕ ΚΙΝΗΤΕΣ ΣΥΣΚΕΥΕΣ



[USER GOOGLE LOGIN ATTEMPT]



[SERVER CAPTURE]

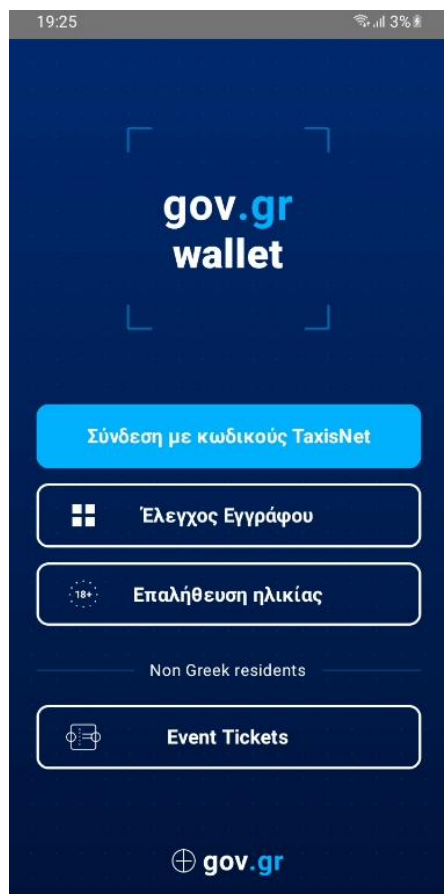
Σημαντικό ρόλο στον αυτοματισμό της επίθεσης παίζει ο διπλός μηχανισμός εντοπισμού captive portal που έχω υλοποιήσει. Από τη μία πλευρά, μέσω του DHCP option 114 σύγχρονες εκδόσεις Android και iOS αναγνωρίζουν αυτόματα την πύλη και την ανοίγουν χωρίς καμία ενέργεια από τον χρήστη. Από την άλλη, για παλαιότερες εκδόσεις και για συσκευές Windows, ο διακομιστής μου παγιδεύει τα γνωστά probe URLs που ελέγχουν τη συνδεσιμότητα και επιστρέφει redirect προς τη σελίδα μου. Έτσι εξασφαλίζεται ότι ανεξάρτητα από το λειτουργικό σύστημα της συσκευής, το παράθυρο του portal θα εμφανιστεί άμεσα.

Η επιτυχία της επίθεσης σφραγίζεται με τη φάση της «αόρατης εξόδου». Για να μην υποψιαστεί το θύμα την υποκλοπή ή εφαρμογή μου ενημερώνει δυναμικά τους κανόνες του firewall τη στιγμή της υποβολής των στοιχείων. Η IP του θύματος απελευθερώνεται και του παρέχεται πλήρης πρόσβαση στο πραγματικό διαδίκτυο μέσω NAT. Το λειτουργικό σύστημα της συσκευής βλέποντας πλέον ότι οι έλεγχοι συνδεσιμότητας περνούν επιτυχώς, κλείνει το παράθυρο του portal και ο χρήστης συνεχίζει την περιήγησή του κανονικά, θεωρώντας ότι απλώς συνδέθηκε σε ένα δωρεάν Wi-Fi. Αυτή η κυκλική προσέγγιση —από την παγίδευση μέχρι την απελευθέρωση— καθιστά την επίθεση εξαιρετικά αποτελεσματική και δύσκολα ανιχνεύσιμη από τον μέσο χρήστη.

FAKE APP ATTACK (GOV WALLET PROTOTYPE)

Στην παρούσα επίθεση αναπτύχθηκε ένα λειτουργικό πρωτότυπο που προσομοιώνει μια εξελιγμένη επίθεση ηλεκτρονικού ψαρέματος (phishing) μέσω κινητής συσκευής. Η επίθεση δεν βασίζεται μόνο σε μια απλή ιστοσελίδα, αλλά χρησιμοποιεί μια "δούρειο" εφαρμογή (malicious app) η οποία εκμεταλλεύεται την οπτική οικειότητα του χρήστη με το επίσημο περιβάλλον του gov.gr wallet για να υποκλέψει διαπιστευτηρίων TaxisNet.

Η διαδικασία ξεκινά με την εγκατάσταση της εφαρμογής, η οποία έχει σχεδιαστεί με τη χρήση σύγχρονων εργαλείων (Jetpack Compose) ώστε να είναι οπτικά πανομοιότυπη με την αυθεντική. Η στρατηγική του επιτιθέμενου βασίζεται στο ότι ο χρήστης, βλέποντας ένα γνώριμο interface, δεν θα υποψιαστεί ότι η διαδικασία αυθεντικοποίησης ελέγχεται πλήρως από την ίδια την εφαρμογή και όχι από το σύστημα.



[GOV WALLET APP]

Η εφαρμογή ζητά κατά την εγκατάσταση μόνο την άδεια χρήσης διαδικτύου, η οποία δεν εμφανίζει προειδοποίηση στον χρήστη και δεν κινεί υποψίες. Η αρχική οθόνη έχει σχεδιαστεί ώστε να αναπαράγει με ακρίβεια το επίσημο γραφιστικό περιβάλλον της εφαρμογής, με το χαρακτηριστικό μπλε gradient, το λογότυπο πλαισιωμένο από τις τέσσερις γωνίες και τα γνωρίμα κουμπιά για σύνδεση, έλεγχο εγγράφων και επαλήθευση ηλικίας. Όλα τα κουμπιά της αρχικής οθόνης οδηγούν στην ίδια ψεύτικη σελίδα αυθεντικοποίησης, ανεξάρτητα από το ποια ενέργεια θεωρεί ο χρήστης ότι ξεκινάει.

Το κρίσιμο σημείο της επίθεσης εντοπίζεται στη στιγμή που ο χρήστης επιλέγει τη "Σύνδεση με κωδικούς TaxisNet". Αντί η εφαρμογή να ανακατευθύνει τον χρήστη σε έναν ασφαλή εξωτερικό browser (όπως ο Chrome), ανοίγει μια εσωτερική οθόνη (WebView) η οποία λειτουργεί ως ένα ψεύτικο Captive Portal. Για να μεγιστοποιηθεί η εξαπάτηση, έχει προστεθεί στο πάνω μέρος μια τεχνητή μπάρα διευθύνσεων που εμφανίζει το "oauth2.gsis.gr" μαζί με το εικονίδιο του λουκέτου, δημιουργώντας μια ψευδαίσθηση ασφάλειας και κρυπτογράφησης HTTPS, ενώ στην πραγματικότητα φορτώνεται μια τοπική, τροποποιημένη σελίδα HTML.

19:26 3%

oauth2.gsis.gr

Γενική Γραμματεία Πληροφορικών Συστημάτων &... ΕΛΛΗΝΙΚΗ ΔΗΜΟΚΡΑΤΙΑ Υπουργείο Ψηφιακής Διακυβέρνησης

Αυθεντικοποίηση Χρηστών English

Σύνδεση

Παρακαλώ εισάγετε τους κωδικούς σας στο TaxisNet για να συνδεθείτε.

Χρήστης:

Κωδικός:

Σύνδεση

Κέντρο Διαλειτουργικότητας (ΚΕ.Δ.) Υπουργείου Ψηφιακής Διακυβέρνησης

[GOV WALLET TAXIS FORM]

Η σελίδα αυτή, η οποία περιλαμβάνεται στα assets της εφαρμογής, περιέχει κώδικα JavaScript που παρακολουθεί τη φόρμα εισαγωγής στοιχείων. Μάλιστα, εφαρμόζεται μια τακτική "ψυχικής κόπωσης" του θύματος: στην πρώτη προσπάθεια σύνδεσης, η εφαρμογή εμφανίζει επίτηδες ένα μήνυμα λάθους ("Αποτυχία Αυθεντικοποίησης"), καθαρίζοντας το πεδίο του κωδικού. Αυτό γίνεται για δύο λόγους: πρώτον, για να φαίνεται η διαδικασία πιο ρεαλιστική (καθώς τα λάθη είναι συνηθισμένα) και δεύτερον, για να διασφαλιστεί ότι ο χρήστης θα πληκτρολογήσει προσεκτικά τα στοιχεία του τη δεύτερη φορά, επιβεβαιώνοντας έτσι την ορθότητά τους για τον επιτιθέμενο.

The screenshot shows a mobile application interface for login. At the top, the status bar displays the time 19:28 and battery level 4%. The app's URL is 'oauth2.gsis.gr'. Below the URL are logos for the 'Εθνική Επιτροπή Πληροφορικών Συστημάτων & ...' and the 'ΕΛΛΗΝΙΚΗ ΔΗΜΟΚΡΑΤΙΑ Υπουργείο Περιφερειακής Διακυβέρνησης'. The main header is 'Αυθεντικοποίηση Χρηστών' with an 'English' button. The title is 'Σύνδεση'. The instruction says: 'Παρακαλώ εισάγετε τους κωδικούς σας στο TaxisNet για να συνδεθείτε.' A red error box contains the text: 'Αποτυχία στην Αυθεντικοποίηση του χρήστη! Η σύνδεσή σας δεν ήταν δυνατή.' Below this are input fields for 'Χρήστης:' (containing 'HELLO_TEST') and 'Κωδικός:' (empty). A blue 'Σύνδεση' button is at the bottom.

[USER LOGIN ERROR]

Η σελίδα έχει αναπτυχθεί με κανονικό HTML, CSS και JavaScript και βρίσκεται αποθηκευμένη μέσα στα assets της εφαρμογής. Η οπτική ταυτότητα έχει αντιγραφεί από την επίσημη πύλη

του TaxisNet, με τα δύο λογότυπα στο πάνω μέρος, το χαρακτηριστικό μπλε banner αυθεντικοποίησης, τη φόρμα σύνδεσης και τον σύνδεσμο στο τέλος της σελίδας. Παρά την παραπλανητική address bar στην πραγματικότητα τίποτα δεν μεταφέρεται μέσω δικτύου κατά τη φόρτωση. Η σελίδα φορτώνεται τοπικά από τη συσκευή, χωρίς δηλαδή να γίνει καμία πραγματική κλήση στο gsis.gr.

Τεχνικά, η υποκλοπή επιτυγχάνεται μέσω μιας "γέφυρας" (JavaScript Bridge) που συνδέει τον κώδικα της ιστοσελίδας με τον κώδικα της Android εφαρμογής. Μόλις ο χρήστης πατήσει το κουμπί της σύνδεσης, η JavaScript στέλνει το username και το password στην κλάση WebAppInterface. Από εκεί, η εφαρμογή αναλαμβάνει την αθόρυβη εξαγωγή των δεδομένων (Data Exfiltration). Χρησιμοποιώντας ένα ξεχωριστό thread για να μην γίνει αντιληπτή καμία καθυστέρηση στη συσκευή και στέλνει ένα HTTP POST αίτημα σε έναν απομακρυσμένο διακομιστή που ελέγχει ο επιτιθέμενος.

19:27 3%

oauth2.gsis.gr

Εννοει Γραμματοσειρά Πληροφοριών Συστημάτων & ...

ΕΛΛΗΝΙΚΗ ΔΗΜΟΚΡΑΤΙΑ
Υπουργείο Ψηφιακής Διακυβέρνησης

Αυθεντικοποίηση Χρηστών English

Σύνδεση

Παρακαλώ εισάγετε τους κωδικούς σας στο
TaxisNet για να συνδεθείτε.

Χρήστης:

HELLO_TEST

Κωδικός:

.....|

Σύνδεση

Κέντρο Διαλειτουργικότητας (ΚΕ.Δ.) Υπουργείου
Ψηφιακής Διακυβέρνησης

[USER LOGIN ATTEMPT]

Η αποστολή των δεδομένων γίνεται σε ξεχωριστό thread, ώστε να μη προκληθεί ορατή καθυστέρηση στο interface και να μη γίνει αντιληπτή η δικτυακή δραστηριότητα. Επιπλέον, η εφαρμογή έχει σχεδιαστεί να επαναλαμβάνει την προσπάθεια αποστολής έως και τρεις φορές σε περίπτωση αστοχίας, εξασφαλίζοντας ότι η διαρροή θα ολοκληρωθεί ακόμα και υπό συνθήκες ασταθούς δικτύου.

Στην πλευρά του επιτιθέμενου, χρησιμοποιείται ένα script σε Python (listener.py), το οποίο είναι ρυθμισμένο να δέχεται αυτά τα αιτήματα. Σε πραγματικές συνθήκες, ο διακομιστής αυτός θα μπορούσε να βρίσκεται οπουδήποτε στον κόσμο, προσβάσιμος μέσω εργαλείων όπως το Cloudflare Tunnel. Ο listener καταγράφει σε πραγματικό χρόνο τα διαπιστευτήρια,

την IP διεύθυνση του θύματος και την ακριβή ώρα της υποκλοπής, αποθηκεύοντάς τα σε ένα αρχείο log για μετέπειτα χρήση.

```
C:\WINDOWS\py.exe x PowerShell x + v
[*] Listener started on 0.0.0.0:8000
[*] Credentials will also be saved to: C:\Users\chari\Documents\security-awareness-simulations\govgrwallet-prototype\captured_credentials.log
[*] Run Cloudflare Tunnel in another terminal:
    cloudflared tunnel --url http://localhost:8000
```

```
C:\WINDOWS\py.exe x PowerShell x + v
[*] Listener started on 0.0.0.0:8000
[*] Credentials will also be saved to: C:\Users\chari\Documents\security-awareness-simulations\govgrwallet-prototype\captured_credentials.log
[*] Run Cloudflare Tunnel in another terminal:
    cloudflared tunnel --url http://localhost:8000

[2026-05-06 19:28:31] NEW CAPTURE from 2a02:587:4c46:a200:95e4:132b:e92e:5c8a
  USERNAME : HELLO_TEST
  PASSWORD : FAKE PASSWORD123456
=====
```

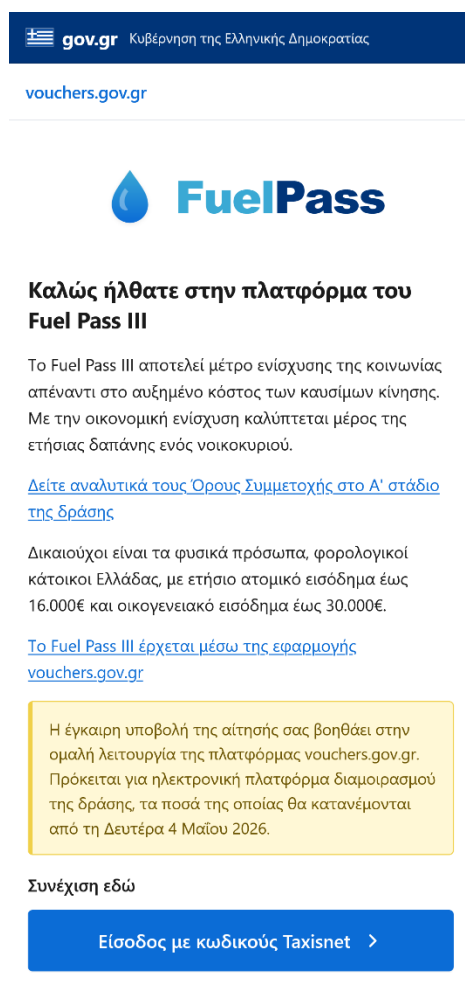
[PYTHON LISTENER]

Για την έκθεση του διακομιστή στο διαδίκτυο, χωρίς να χρειάζεται στατική IP ή ρυθμίσεις στο router, χρησιμοποίησα το Cloudflare Tunnel. Με μία απλή εντολή ο τοπικός listener γίνεται προσβάσιμος μέσω ενός δημόσιου URL με έγκυρο HTTPS πιστοποιητικό. Έτσι η εφαρμογή στέλνει τα διαπιστευτήρια μέσω κρυπτογραφημένης σύνδεσης σε ένα φαινομενικά αξιόπιστο domain, χωρίς προειδοποιήσεις από το λειτουργικό. Σημειώνεται επίσης ότι ο listener λαμβάνει την πραγματική IP του θύματος μέσω ειδικού header που προσθέτει το Cloudflare, και όχι την εσωτερική IP του τούνελ.

Συμπερασματικά, η προσομοίωση αυτή αναδεικνύει πόσο εύκολα μπορεί να παρακαμφθεί η εμπιστοσύνη του χρήστη όταν μια κακόβουλη εφαρμογή ελέγχει το περιβάλλον παρουσίασης (UI) και τη ροή των δεδομένων, υπογραμμίζοντας την κρίσιμη σημασία της αποφυγής εγκατάστασης εφαρμογών από μη επίσημες πηγές.

SMS Phishing Attack (Fuel Pass III Portal Prototype)

Η διαδικασία της επίθεσης ξεκινά με μια πολύ προσεκτικά σχεδιασμένη προσπάθεια κοινωνικής μηχανικής, η οποία βασίζεται στην εκμετάλλευση της επικαιρότητας και της ανάγκης του πολίτη για κρατική ενίσχυση. Ο επιτιθέμενος στέλνει ένα μήνυμα SMS στο υποψήφιο θύμα, το οποίο περιλαμβάνει έναν σύνδεσμο που μοιάζει εξαιρετικά με τον επίσημο του gov.gr. Στο περιβάλλον του εργαστηρίου μας, χρησιμοποιούμε το path /fuelpass/appfront, το οποίο σε μια πραγματική επίθεση θα συνοδευόταν από ένα typosquatted domain, ώστε να μην κινήσει υποψίες στον χρήστη που το βλέπει από την οθόνη του κινητού του.



[FUEL PASS III LANDING PAGE]

Η σελίδα δεν περιορίζεται σε απλή προσομοίωση. Έχει συμπεριληφθεί εκτενές ενημερωτικό υλικό με συχνές ερωτήσεις σχετικά με τους δικαιούχους, τα εισοδηματικά κριτήρια, τη διαδικασία υποβολής και τους τρόπους πληρωμής, καθώς και αναφορές σε τηλέφωνα εξυπηρέτησης και επίσημες υπηρεσίες. Η ύπαρξη όλων αυτών των στοιχείων ενισχύει σημαντικά την αξιοπιστία της σελίδας στα μάτια του θύματος, καθώς οι κακόβουλες σελίδες σπάνια διαθέτουν τόσο ολοκληρωμένο περιεχόμενο.

Μόλις ο χρήστης πατήσει τον σύνδεσμο, οδηγείται στην κεντρική σελίδα υποδοχής του Fuel Pass III, η οποία φαίνεται στην παραπάνω εικόνα. Εδώ έχει γίνει μια προσπάθεια για απόλυτη οπτική πιστότητα, χρησιμοποιώντας τα επίσημα χρώματα, το εθνόσημο και τη δομή των σελίδων του gov.gr. Ο χρήστης βλέπει μια πλήρη πλατφόρμα με ερωταπαντήσεις και οδηγίες, γεγονός που τον εφησυχάζει και τον οδηγεί στο να πατήσει το κουμπί για την είσοδο με κωδικούς Taxisnet θεωρώντας ότι πρόκειται για την επίσημη διαδικασία αυθεντικοποίησης.

Γενική Γραμματεία
Πληροφοριακών
Συστημάτων &
Ψηφιακής
Διακυβέρνησης

ΕΛΛΗΝΙΚΗ
ΔΗΜΟΚΡΑΤΙΑ
Υπουργείο Ψηφιακής
Διακυβέρνησης

Αυθεντικοποίηση Χρηστών English

Σύνδεση

Παρακαλώ εισάγετε τους κωδικούς σας στο
TaxisNet για να συνδεθείτε.

Χρήστης:

Κωδικός:

Σύνδεση

Κέντρο Διαλειτουργικότητας (ΚΕ.Δ.) Υπουργείου
Ψηφιακής Διακυβέρνησης

[TAXIS FORM]

Στη συνέχεια, η επίθεση περνά στο πιο κρίσιμο στάδιο, αυτό της υποκλοπής. Ο χρήστης μεταφέρεται σε μια σελίδα που αποτελεί πιστό αντίγραφο της πύλης εισόδου της Γενικής Γραμματείας Πληροφοριακών Συστημάτων, όπως φαίνεται στην εικόνα της φόρμας. Η σελίδα ζητά το όνομα χρήστη και τον κωδικό πρόσβασης, ενώ η τεχνική που χρησιμοποιούμε στο παρασκήνιο είναι ιδιαίτερα εξελιγμένη.

[TAXIS USER LOGIN]

Σημαντική παράμετρος της επίθεσης είναι ότι τα πεδία εισόδου διαθέτουν τις κατάλληλες ρυθμίσεις προσβασιμότητας, ώστε να ενεργοποιούνται οι ενσωματωμένοι password managers του browser του θύματος. Με αυτόν τον τρόπο, αν το θύμα έχει αποθηκεύσει τους κωδικούς του στην επίσημη σελίδα του TaxisNet, ο browser τους προτείνει αυτόματα και στην ψεύτικη πύλη μου. Αυτή η λεπτομέρεια αυξάνει αισθητά την επιτυχία της επίθεσης, καθώς ο χρήστης βλέπει το γνώριμο pop-up του password manager και αποκτά εμπιστοσύνη στη σελίδα.

Κατά τη διάρκεια της πληκτρολόγησης των στοιχείων, το script exfiltration χρησιμοποιεί τη μέθοδο navigator.sendBeacon. Αυτή η μέθοδος επιτρέπει στα δεδομένα να σταλούν στον server μας ακόμη και αν ο χρήστης κλείσει απότομα τον browser ή γίνει γρήγορη ανακατεύθυνση, διασφαλίζοντας ότι η υποκλοπή θα ολοκληρωθεί με επιτυχία.

The screenshot shows a mobile web interface for TaxisNet. At the top, there are logos for the General Secretariat of Information Systems and Digital Governance, the Hellenic Republic, and the Ministry of Digital Governance. Below this is a header with 'Αυθεντικοποίηση Χρηστών' and an 'English' button. The main heading is 'Σύνδεση'. Below it, a message asks the user to enter their credentials to connect to TaxisNet. A red error box states: 'Αποτυχία στην Αυθεντικοποίηση του χρήστη! Η σύνδεσή σας δεν ήταν δυνατή. Παρακαλώ προσπαθήστε ξανά.' Below the error box are input fields for 'Χρήστης:' (containing 'TEST_NAME') and 'Κωδικός:'. A blue 'Σύνδεση' button is at the bottom. The footer mentions the 'Κέντρο Διαλειτουργικότητας (ΚΕ.Δ.) Υπουργείου Ψηφιακής Διακυβέρνησης'.

[TAXIS ERROR]

Ένα ιδιαίτερο χαρακτηριστικό της επίθεσης που προσθέτει ρεαλισμό είναι η στρατηγική της διπλής προσπάθειας. Όταν ο χρήστης εισάγει για πρώτη φορά τα στοιχεία του, η σελίδα εμφανίζει ένα τεχνητό μήνυμα σφάλματος, όπως παρατηρούμε στην εικόνα TAXIS ERROR.

Αυτό γίνεται σκόπιμα για να εξαναγκάσει τον χρήστη να ξαναγράψει τα στοιχεία του, επιβεβαιώνοντας την ορθότητα των διαπιστευτηρίων και μειώνοντας την πιθανότητα τυπογραφικού λάθους.

Επιπλέον της ψυχολογικής διάστασης, η διπλή προσπάθεια λειτουργεί και ως μηχανισμός επιβεβαίωσης για τον επιτιθέμενο. Αν ο χρήστης πληκτρολογήσει διαφορετικό κωδικό στις δύο προσπάθειες καταγράφονται και οι δύο εκδοχές, καλύπτοντας έτσι και πιθανά τυπογραφικά λάθη. Έτσι ο επιτιθέμενος αποκτά ολοκληρωμένη εικόνα των στοιχείων που χρησιμοποιεί το θύμα.

[illegible]

[SERVER SETUP]

Στην πλευρά του επιτιθέμενου, ο server είναι ήδη έτοιμος να υποδεχθεί τα δεδομένα. Η τεχνική υποδομή βασίζεται σε Node.js και Express, επιτρέποντας την άμεση καταγραφή κάθε κίνησης.

```
PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS
node - server + - - - - -

PS C:\Users\chari\Documents\security-awareness-simulations\SMS-phishing-prototype\server> npm install

found 0 vulnerabilities
PS C:\Users\chari\Documents\security-awareness-simulations\SMS-phishing-prototype\server> node server.js
SMS phishing lab listening on http://localhost:3000/fuelpass/appfront
Captures (text): C:\Users\chari\Documents\security-awareness-simulations\SMS-phishing-prototype\server\captures.txt
Captures (jsonl): C:\Users\chari\Documents\security-awareness-simulations\SMS-phishing-prototype\server\captures.jsonl

[6/5/2026, 6:31:29 μ.μ.] TAXISNET CAPTURE - IP: 127.0.0.1
username      : TEST_NAME
password      : password123456
attempt       : 1
user-agent    : Mozilla/5.0 (iPhone; CPU iPhone OS 18_6 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0 Mobile/15E148 Safari/604.1
=====
```

[USER CREDENTIALS CAPTURE]

Η καταγραφή των δεδομένων γίνεται σε δύο παράλληλες μορφές. Η πρώτη είναι ένα αρχείο κειμένου σε ανθρώπινα αναγνώσιμη μορφή, με σαφή διαχωρισμό κάθε υποκλοπής σε ξεχωριστή εγγραφή. Η δεύτερη είναι ένα αρχείο σε δομημένη μορφή JSON Lines, κατάλληλη για στατιστική επεξεργασία και ανάλυση των δεδομένων στο πλαίσιο της παρούσας πτυχιακής. Έτσι, παράλληλα με την επίδειξη της επίθεσης, διατηρείται και ποσοτικό υλικό για τη μελέτη των αποτελεσμάτων.

Τέλος, όλα τα κλεμμένα στοιχεία καταλήγουν στον server μας και καταγράφονται στην κονσόλα και στα αρχεία καταγραφής. Όπως φαίνεται στην εικόνα της υποκλοπής, ο επιτιθέμενος έχει πλέον πρόσβαση στο username, το password, την IP διεύθυνση και τον τύπο της συσκευής του θύματος.

```
Welcome | captures.txt x
SMS-phishing-prototype > server > captures.txt
1
2 --- Session started: 5/5/2026, 9:25:12 μ.μ. ---
3
4 [5/5/2026, 9:25:39 μ.μ.] TAXISNET CAPTURE - IP: 127.0.0.1
5 username      : test
6 password      : 12344
7 attempt       : 1
8 user-agent    : Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0
9 =====
10
11 --- Session started: 6/5/2026, 6:28:14 μ.μ. ---
12
13 [6/5/2026, 6:31:29 μ.μ.] TAXISNET CAPTURE - IP: 127.0.0.1
14 username      : TEST_NAME
15 password      : password123456
16 attempt       : 1
17 user-agent    : Mozilla/5.0 (iPhone; CPU iPhone OS 18_6 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0 Mobile/15E148 Safari/604.1
18 =====
19
```

[CAPTURES EXPORT FILE]

Η διαδικασία ολοκληρώνεται με την εξαγωγή των δεδομένων σε δομημένη μορφή, όπως φαίνεται στην τελευταία εικόνα του export file. Ο επιτιθέμενος διαθέτει πλέον μια πλήρη λίστα με τα διαπιστευτήρια των θυμάτων, έτοιμη για χρήση, ενώ το θύμα δεν αντιλήφθηκε ποτέ την υποκλοπή.

Η συγκεκριμένη επίθεση καταδεικνύει με σαφήνεια ότι το πιο επικίνδυνο στοιχείο δεν είναι κάποια τεχνική ευπάθεια του λειτουργικού ή του browser, αλλά ο τρόπος με τον οποίο ο χρήστης αντιλαμβάνεται οπτικά την αξιοπιστία μιας σελίδας. Όσο πιο πειστική είναι η εμφάνιση και το URL, τόσο μικρότερη είναι η πιθανότητα το θύμα να σταματήσει για να ελέγξει τη γνησιότητα της πύλης στην οποία πρόκειται να εισάγει τα στοιχεία του.

Συγκριτική Ανάλυση των Τριών Επιθέσεων

Η κατασκευή των τριών παραπάνω πρωτοτύπων μου επέτρεψε να αξιολογήσω εκ των έσω τα χαρακτηριστικά κάθε επίθεσης και να διαπιστώσω ποιες παράμετροι την καθιστούν αποτελεσματική ή ευάλωτη σε ανίχνευση. Παρότι οι τρεις επιθέσεις διαφέρουν ριζικά ως προς τη φύση τους, αφού η πρώτη επιδρά στο επίπεδο του δικτύου, η δεύτερη στο επίπεδο της εφαρμογής και η τρίτη στο επίπεδο των μηνυμάτων, υπάρχει ένα σύνολο κοινών αξόνων με βάση τους οποίους μπορούν να συγκριθούν.

Τεχνική Πολυπλοκότητα

Η επίθεση Evil Twin είναι μακράν η πιο απαιτητική από τεχνική σκοπιά. Προϋποθέτει την κατανόηση πολλαπλών δικτυακών πρωτοκόλλων, τη σωστή παραμετροποίηση εργαλείων χαμηλού επιπέδου όπως το hostapd, το dnsmasq και το iptables, καθώς και την ικανότητα να εξισορροπεί δύο αντικρουόμενες απαιτήσεις. Από τη μία να παγιδεύει τη συσκευή του θύματος ώστε να εμφανιστεί το captive portal, από την άλλη να παραχωρεί δυναμικά πρόσβαση στο πραγματικό διαδίκτυο μετά την υποκλοπή. Κάθε λάθος στους κανόνες του τοίχου προστασίας μπορεί είτε να αποκαλύψει την επίθεση είτε να αφήσει το θύμα μόνιμα αποκλεισμένο. Η επίθεση Gov Wallet έρχεται στη δεύτερη θέση σε πολυπλοκότητα. Απαιτεί ανάπτυξη ολοκληρωμένης Android εφαρμογής με σύγχρονο UI, ενσωμάτωση WebView, υλοποίηση JavaScript bridge προς τον native κώδικα και διαχείριση δικτυακών κλήσεων σε ξεχωριστό thread. Η επίθεση SMS phishing είναι η απλούστερη υλοποιήσιμη, καθώς αρκείται σε δύο στατικές HTML σελίδες και έναν ελαφρύ Node.js διακομιστή που καταγράφει τις υποβολές.

Κόστος Υλοποίησης

Σε επίπεδο κόστους, η Evil Twin είναι η μόνη επίθεση που απαιτεί φυσικό εξοπλισμό. Χρειάζεται έναν εξωτερικό προσαρμογέα Wi-Fi με υποστήριξη Access Point Mode και μια συσκευή που να τρέχει Linux. Το κόστος αυτό κυμαίνεται περίπου σε σαράντα έως ογδόντα ευρώ συνολικά. Επιπλέον, ο επιτιθέμενος πρέπει φυσικά να βρίσκεται σε εύλογη απόσταση

από τα θύματα, γεγονός που περιορίζει σημαντικά την κλίμακα της επίθεσης και αυξάνει τον προσωπικό κίνδυνο. Η επίθεση Gov Wallet έχει μηδενικό υλικό κόστος αλλά απαιτεί χρόνο ανάπτυξης και διανομή του APK. Επίσης, για να εκτελεστεί χρειάζεται να πειστεί το θύμα να ενεργοποιήσει την εγκατάσταση από άγνωστες πηγές, διαδικασία που σήμερα συνοδεύεται από προειδοποιητικά μηνύματα στις περισσότερες συσκευές. Η επίθεση SMS phishing είναι σχεδόν ασύμμετρη ως προς το κόστος. Με την ίδια υποδομή ο επιτιθέμενος μπορεί να στοχεύσει χιλιάδες θύματα ταυτόχρονα. Το μόνο επιπλέον κόστος είναι η αποστολή των SMS, η οποία σε αγορές όπως οι ευρωπαϊκές μπορεί να γίνει σχεδόν δωρεάν μέσα από διεθνείς υπηρεσίες spoofing ή κακόβουλα SIM gateways.

Αποτελεσματικότητα Εξαπάτησης

Η αποτελεσματικότητα κάθε επίθεσης εξαρτάται από διαφορετικούς ψυχολογικούς μηχανισμούς. Η Evil Twin βασίζεται στη συνήθεια του χρήστη να εμπιστεύεται ανοιχτά Wi-Fi με γνωστό όνομα. Καθώς το λειτουργικό σύστημα εμφανίζει αυτόματα το captive portal, η εμπιστοσύνη που του παρέχει αυτό το γνωστό μηχανισμό μεταφέρεται στη σελίδα μου. Είναι πολύ αποτελεσματική σε δημόσιους χώρους όπου ο χρήστης βρίσκεται ήδη σε λειτουργία αναζήτησης δικτύου. Η Gov Wallet εκμεταλλεύεται την οπτική οικειότητα και την εξουσιοδότηση που εμπνέει η επίσημη αισθητική του ελληνικού δημοσίου. Είναι ιδιαίτερα αποτελεσματική όταν διανεμηθεί μέσω τρίτων καναλιών που ήδη απολαμβάνουν εμπιστοσύνη, όπως ομάδες σε εφαρμογές messaging ή ιστοσελίδες κοινωνικών μέσων. Η επίθεση SMS phishing είναι ίσως η πιο αποτελεσματική σε όρους ποσοστού επιτυχίας ανά αποστολή, καθώς συνδυάζει τρία ισχυρά στοιχεία: την εξατομικευμένη φύση του SMS που το διαφοροποιεί από το μαζικό email, την επικαιρότητα της κρατικής ενίσχυσης που δημιουργεί αίσθημα ευκαιρίας ή απώλειας, και την οπτική πιστότητα του ψεύτικου portal που είναι πρακτικά αδύνατο να ξεχωρίσει από το αυθεντικό σε μικρή οθόνη.

Ανιχνευσιμότητα

Από την οπτική γωνία της ανίχνευσης, η Evil Twin αφήνει τα περισσότερα ίχνη. Ο επιτιθέμενος πρέπει να βρίσκεται φυσικά κοντά, η συσκευή του εκπέμπει σήμα που μπορεί να εντοπιστεί από εργαλεία wireless monitoring, ενώ η ίδια η ύπαρξη πολλαπλών access points με το ίδιο όνομα μπορεί να γίνει αντιληπτή από συστήματα διαχείρισης ασύρματων δικτύων σε εταιρικά περιβάλλοντα. Η επίθεση Gov Wallet είναι πιο δύσκολο να ανιχνευθεί από τη στιγμή που το APK θα εγκατασταθεί, αλλά η αρχική προειδοποίηση του Android για άγνωστες πηγές αποτελεί φραγμό που λειτουργεί υπέρ της άμυνας. Η επίθεση SMS phishing είναι η πιο δύσκολη στην ανίχνευση επειδή πατάει σε υποδομές κινητής τηλεφωνίας που από τη φύση τους δεν διαθέτουν αυθεντικοποίηση αποστολέα, ενώ τα κενά μεταξύ της λήψης του

μηνύματος, της επίσκεψης στη σελίδα και της υποβολής των στοιχείων είναι τόσο μικρά που τα αυτοματοποιημένα συστήματα προστασίας δύσκολα προλαβαίνουν να αντιδράσουν.

Συγκριτικός Πίνακας

Χαρακτηριστικό	Evil Twin	Fake Mobile App	SMS Phishing
Επίπεδο επίθεσης	Δίκτυο	Εφαρμογή	Μήνυμα και Web
Τεχνική πολυπλοκότητα	Υψηλή	Μέτρια προς υψηλή	Χαμηλή προς μέτρια
Απαίτηση φυσικής εγγύτητας	Ναι	Όχι	Όχι
Κόστος υλοποίησης	40-80€ σε εξοπλισμό	Μηδενικό υλικό κόστος	Σχεδόν μηδενικό
Δυνατότητα κλιμάκωσης	Περιορισμένη	Μέτρια	Πολύ υψηλή
Ψυχολογικός μοχλός	Συνήθεια σε ανοιχτά δίκτυα	Οπτική οικειότητα με κρατική εφαρμογή	Επικαιρότητα και πίεση χρόνου
Παρακάμπτει HTTPS	Ναι, μέσω captive portal	Ναι, μέσω τοπικού WebView	Ναι, μέσω έγκυρου πιστοποιητικού σε ψεύτικο domain
Ευκολία ανίχνευσης από χρήστη	Μέτρια προς υψηλή	Χαμηλή	Πολύ χαμηλή
Ευκολία ανίχνευσης τεχνικά	Μέτρια	Χαμηλή	Χαμηλή
Πιθανός όγκος θυμάτων	Διαφέρει ανάλογα την περιοχή διεξαγωγής	Εκατοντάδες	Χιλιάδες έως δεκάδες χιλιάδες

Από τον παραπάνω πίνακα προκύπτει ένα ενδιαφέρον συμπέρασμα. Όσο μειώνεται η τεχνική πολυπλοκότητα της επίθεσης τόσο αυξάνεται η δυνατότητα κλιμάκωσης και τόσο δυσκολότερη γίνεται η ανίχνευσή της. Η επίθεση Evil Twin είναι τεχνικά εντυπωσιακή αλλά περιορισμένης εμβέλειας, ενώ η επίθεση SMS phishing είναι σχετικά απλή αλλά μπορεί να φτάσει σε αδιανόητο όγκο θυμάτων με ελάχιστο κόστος. Αυτή η αντίστροφη σχέση εξηγεί γιατί στην πραγματικότητα η συντριπτική πλειοψηφία των επιθέσεων Κοινωνικής Μηχανικής που καταγράφονται στατιστικά ανήκει στη μορφή του phishing και smishing, ενώ οι επιθέσεις Evil Twin συναντώνται κυρίως σε στοχευμένα σενάρια εμπορικής κατασκοπείας ή ξενοδοχειακών χώρων.

Αντίμετρα και Μέτρα Προστασίας

Η ανάδειξη του τρόπου με τον οποίο λειτουργεί κάθε επίθεση δεν έχει νόημα αν δεν συνοδεύεται από τη συζήτηση του τρόπου με τον οποίο μπορεί να αντιμετωπιστεί. Στη συνέχεια εξετάζω τα αντίμετρα για κάθε μία από τις τρεις επιθέσεις, με προσέγγιση που λαμβάνει υπόψη τόσο την τεχνική διάσταση όσο και τη διάσταση της εκπαίδευσης του χρήστη. Αυτή η διπλή προσέγγιση είναι αναγκαία γιατί καμία από τις δύο διαστάσεις από μόνη της δεν επαρκεί. Η τεχνολογία χωρίς εκπαίδευση δημιουργεί χρήστες που στηρίζονται τυφλά στους μηχανισμούς ασφαλείας, ενώ η εκπαίδευση χωρίς τεχνολογία αφήνει υπερβολικά μεγάλο φορτίο επαγρύπνησης πάνω στον τελικό χρήστη.

Αντίμετρα για την Επίθεση Evil Twin

Σε τεχνικό επίπεδο, η αποτελεσματικότερη άμυνα κατά της επίθεσης Evil Twin βρίσκεται στη χρήση κρυπτογραφημένων διεξόδων από τη συσκευή του χρήστη, οι οποίες δεν εξαρτώνται από την αξιοπιστία του υποκείμενου δικτύου. Η χρήση αξιόπιστου παρόχου VPN κάνει την επίθεση πρακτικά αδύνατη, καθώς ακόμη και αν ο χρήστης συνδεθεί στο ψεύτικο access point, ο ίδιος ο VPN client θα αποτύχει να συνδεθεί στον διακομιστή του και θα ειδοποιήσει τον χρήστη για την παρουσία ασυνήθιστου περιβάλλοντος. Η ενεργοποίηση του DNS over HTTPS ή του DNS over TLS στο ίδιο το λειτουργικό σύστημα της συσκευής είναι ένα δεύτερο σημαντικό μέτρο, καθώς απαλείφει τη δυνατότητα του επιτιθέμενου να παραποιεί τις απαντήσεις DNS μέσω του τοπικού του dnsmasq. Σε εταιρικά περιβάλλοντα, η εγκατάσταση ασύρματων συστημάτων ανίχνευσης παρείσφρησης που εντοπίζουν την παρουσία rogue access points με ίδιο SSID είναι σχεδόν υποχρεωτικό μέτρο. Επιπλέον, η κατάργηση της αυτόματης σύνδεσης σε γνωστά δίκτυα στις συσκευές των εργαζομένων μειώνει σημαντικά την επιφάνεια επίθεσης, καθώς ο χρήστης δεν συνδέεται πλέον σιωπηρά κάθε φορά που η συσκευή του αναγνωρίζει ένα παρόμοιο όνομα δικτύου. Σε επίπεδο πρωτοκόλλων, η μετάβαση στο WPA3 με Enhanced Open Mode προσφέρει βελτιωμένη προστασία ακόμη και για ανοιχτά δίκτυα, αν και η εκτεταμένη υιοθέτησή του βρίσκεται ακόμη σε εξέλιξη.

Σε επίπεδο εκπαίδευσης, ο χρήστης πρέπει να κατανοήσει ότι η ίδια η ένδειξη «Σύνδεση στο δίκτυο» που εμφανίζεται από το λειτουργικό σύστημα δεν αποτελεί από μόνη της απόδειξη γνησιότητας του δικτύου. Είναι μια αυτοματοποιημένη απάντηση σε τεχνικό ερέθισμα και όχι έγκριση από κάποιον ανθρώπινο φορέα. Ο χρήστης πρέπει επίσης να εκπαιδευτεί στο να αμφιβάλλει για ανοιχτά δίκτυα σε χώρους όπου δεν έχει εμπιστοσύνη, να μην εισάγει διαπιστευτήρια λογαριασμών Google, Microsoft ή Apple σε σελίδες σύνδεσης Wi-Fi, καθώς αυτές οι πλατφόρμες σε καμία περίπτωση δεν εμπλέκονται στη διαδικασία αυθεντικοποίησης για πρόσβαση σε δίκτυο επισκεπτών, και να επιβεβαιώνει την

αυθεντικότητα του δικτύου ζητώντας το ακριβές όνομά του από τον φυσικό χώρο όπου βρίσκεται. Ένα ακόμη σημαντικό σημείο εκπαίδευσης αφορά την ίδια τη συμπεριφορά της συσκευής. Όταν ένας χρήστης αντιληφθεί ότι η συσκευή του εμφανίζει captive portal σε χώρο που γνωρίζει ότι έχει WPA2 δίκτυο, αυτό είναι μια αξιόπιστη ένδειξη ότι έχει συνδεθεί σε ψεύτικο access point.

Αντίμετρα για την Επίθεση Gov Wallet

Σε τεχνικό επίπεδο, η πρώτη γραμμή άμυνας απέναντι σε κακόβουλες εφαρμογές είναι η ίδια η αρχιτεκτονική του Android που απαιτεί ρητή ενεργοποίηση της εγκατάστασης από άγνωστες πηγές. Η ρύθμιση αυτή πρέπει να παραμένει απενεργοποιημένη και ο χρήστης να εγκαθιστά εφαρμογές αποκλειστικά μέσα από το Google Play Store ή το επίσημο App Store για το iOS. Σε επίπεδο πλατφόρμας, η Google έχει αναπτύξει το Play Protect που σαρώνει τις εγκατεστημένες εφαρμογές για ύποπτη συμπεριφορά, ενώ τα σύγχρονα Android διαθέτουν μηχανισμούς που εμφανίζουν προειδοποιήσεις σε κάθε προσπάθεια εγκατάστασης APK εκτός Play Store. Στο επίπεδο της εφαρμογής, οι μηχανισμοί ψηφιακής υπογραφής των APK αποτρέπουν την παραποίηση γνωστών εφαρμογών, αν και το συγκεκριμένο prototype αναπαράγει την οπτική της gov.gr wallet χωρίς να επιχειρεί να υποδυθεί την ίδια την ψηφιακή ταυτότητά της. Σε εταιρικά περιβάλλοντα, η χρήση Mobile Device Management επιτρέπει στους διαχειριστές να επιβάλουν whitelist εγκεκριμένων εφαρμογών και να αποκλείουν κατηγορηματικά την εγκατάσταση από άγνωστες πηγές. Σε επίπεδο πολιτείας, η ύπαρξη επίσημων αποθετηρίων όπως το Play Store και η αυστηρή σύνδεση κρατικών εφαρμογών αποκλειστικά με αυτά τα κανάλια διανομής αποτελεί ίσως το πιο ισχυρό αντίμετρο.

Σε επίπεδο εκπαίδευσης, ο χρήστης πρέπει να αντιληφθεί ότι η οπτική ομοιότητα μιας εφαρμογής δεν αποτελεί απόδειξη γνησιότητας. Πρέπει να εκπαιδευτεί στο να αναζητά την επίσημη εφαρμογή αποκλειστικά μέσα από το Play Store ή το App Store, να ελέγχει τον επίσημο εκδότη της εφαρμογής, που στην περίπτωση του gov.gr είναι το Υπουργείο Ψηφιακής Διακυβέρνησης, και να αμφιβάλλει για κάθε εφαρμογή που λαμβάνει μέσω συνδέσμου, email ή messaging πλατφόρμας. Επιπλέον, ο χρήστης πρέπει να ξέρει ότι όταν μια εφαρμογή του ζητά να εισάγει διαπιστευτήρια TaxisNet σε εσωτερική οθόνη και όχι μέσω εξωτερικού browser, αυτό από μόνο του αποτελεί κόκκινη σημαία. Η σωστή διαδικασία αυθεντικοποίησης μέσω OAuth2 ξεκινά πάντα με μετάβαση σε εξωτερικό browser, αλλαγή του domain στην address bar σε oauth2.gsis.gr με γνήσιο HTTPS πιστοποιητικό και επιστροφή στην εφαρμογή μετά την επιτυχή σύνδεση. Η εκπαίδευση του χρήστη να αναγνωρίζει αυτή τη ροή είναι ίσως το πιο αποτελεσματικό μέτρο, καθώς η αναπαραγωγή ενός πραγματικού OAuth2 redirect σε εξωτερικό Chrome απαιτεί από τον επιτιθέμενο πολύ μεγαλύτερη υποδομή που είναι ευκολότερα ανιχνεύσιμη.

Αντίμετρα για την Επίθεση SMS Phishing

Σε τεχνικό επίπεδο, η άμυνα κατά του SMS phishing απαιτεί συνδυασμό μέτρων σε πολλαπλά επίπεδα της αλυσίδας μετάδοσης. Οι πάροχοι κινητής τηλεφωνίας έχουν εδώ τον πιο σημαντικό ρόλο, καθώς διαθέτουν τη δυνατότητα να ανιχνεύσουν μαζική αποστολή ομοιόμορφων μηνυμάτων από ίδια προέλευση και να ενεργοποιήσουν φίλτρα που μπλοκάρουν την παράδοσή τους. Η εφαρμογή του πρωτοκόλλου SMS Firewall σε επίπεδο παρόχου είναι το αντίστοιχο των spam filters του email και έχει αρχίσει να υιοθετείται σε αρκετές αγορές. Στο επίπεδο της συσκευής, τα σύγχρονα Android και iOS διαθέτουν λειτουργίες αναγνώρισης ανεπιθύμητων μηνυμάτων που μαθαίνουν από την κοινότητα και προειδοποιούν τον χρήστη για ύποπτα SMS. Στο επίπεδο του browser, οι κύριοι browsers κρατούν λίστες γνωστών phishing domains και εμφανίζουν προειδοποιητικές οθόνες όταν ο χρήστης επιχειρεί να επισκεφθεί ένα από αυτά. Η επίσκεψη ενός νέου phishing site γίνεται για πρώτη φορά πριν προλάβει να καταχωρηθεί στις λίστες αυτές, αλλά κάθε επόμενη επίσκεψη ανιχνεύεται. Σε επίπεδο πολιτείας, η συνεργασία της Δίωξης Ηλεκτρονικού Εγκλήματος με τους παρόχους και τους κατόχους domain για άμεσο κατέβασμα phishing υποδομών είναι κρίσιμη. Επιπλέον, η ενίσχυση μηχανισμών sender ID validation σε επίπεδο πρωτοκόλλου SMS, αν και τεχνικά πολύπλοκη, αποτελεί τη μακροπρόθεσμη λύση. Σε επίπεδο πλατφόρμας του gov.gr, η υιοθέτηση επίσημου brand identity με μοναδικό sender ID και η συστηματική επικοινωνία προς τους πολίτες ότι το gov.gr ποτέ δεν στέλνει συνδέσμους για TaxisNet σύνδεση μέσω SMS λειτουργεί ως αντίβαρο.

Σε επίπεδο εκπαίδευσης, ο χρήστης πρέπει να εσωτερικεύσει την αρχή ότι κανένα κρατικό SMS δεν περιέχει σύνδεσμο που οδηγεί σε σελίδα σύνδεσης TaxisNet. Η ανανέωση κωδικών, η υποβολή αιτήσεων και η αυθεντικοποίηση σε υπηρεσίες του δημοσίου γίνονται πάντα μέσω της πύλης gov.gr ή των επίσημων εφαρμογών, με τον χρήστη να ξεκινά τη διαδικασία ο ίδιος. Πρέπει επίσης να εκπαιδευτεί να ελέγχει με προσοχή τη διεύθυνση URL στην οποία πρόκειται να εισάγει στοιχεία, λαμβάνοντας υπόψη ότι η πραγματική σελίδα του TaxisNet εμφανίζεται πάντα στο domain gsis.gr και όχι σε παραλλαγές όπως vouchers-gov.gr ή gov-gr.com. Σημαντικό σημείο εκπαίδευσης είναι η αναγνώριση της αίσθησης πίεσης χρόνου ως κόκκινης σημαίας. Όταν ένα μήνυμα προτρέπει τον χρήστη να υποβάλει αίτηση εντός σύντομης προθεσμίας ή να ενεργήσει αμέσως για να μη χάσει μια ευκαιρία, αυτή η ίδια η πίεση είναι ένδειξη πιθανής επίθεσης. Οι γνώσεις κρατικές υπηρεσίες δίνουν επαρκή χρόνο και δεν εξαναγκάζουν ποτέ τον πολίτη να ενεργήσει βιαστικά. Τέλος, η συνήθεια του χρήστη να χρησιμοποιεί διαφορετικούς κωδικούς για διαφορετικές υπηρεσίες και να ενεργοποιεί την επαλήθευση δύο παραγόντων όπου αυτό είναι διαθέσιμο, μειώνει δραματικά τη ζημιά ακόμη και σε περίπτωση επιτυχούς phishing επίθεσης.